BÁO CÁO DỰ ÁN | ISSUE #21

# MindSprintAI

## Sản phẩm, tầm nhìn MVP và phân tích rủi ro

| | |
|---|---|
| **Người phụ trách** | Minh Chiến |
| **Ngày rà soát** | 14/10/2026 |
| **Mốc mã nguồn** | main \| b890dcc |
| **Phạm vi** | Báo cáo sản phẩm, chi phí AI, bảo mật và lộ trình |

*Tài liệu phân biệt nội dung đã có trong mã nguồn với đề xuất phát triển. Cấu hình trong repository không tự chứng minh dịch vụ production đang hoạt động.*

# Mục lục

1. Tóm tắt . . . 3

2. Vấn đề, người dùng và tầm nhìn MVP . . . 3

2.1 Vấn đề cần giải quyết . . . 3

2.2 Người dùng mục tiêu . . . 3

2.3 Mục tiêu MVP . . . 3

3. Phạm vi chức năng hiện có . . . 3

3.1 Ngoài phạm vi MVP . . . 4

4. Kiến trúc và luồng dữ liệu . . . 4

4.1 Triển khai và CI . . . 4

5. Rủi ro chi phí AI và biện pháp hiện có . . . 4

5.1 Nguồn phát sinh chi phí . . . 4

5.2 Cơ chế trong mã nguồn liên quan issue #12 . . . 4

5.3 Mức hiệu quả đã biết và việc cần đo . . . 5

6. Bảo mật và quyền riêng tư . . . 5

6.1 Kiểm soát đang có . . . 5

6.2 Rủi ro còn lại . . . 5

7. Rủi ro sản phẩm và vận hành . . . 6

8. Kiểm thử và bằng chứng . . . 6

9. Hướng phát triển . . . 6

Ưu tiên trước khi phát hành rộng . . . 6

Ngoài MVP . . . 6

10. Kết luận . . . 6

Tài liệu tham chiếu . . . 7

# 1. Tóm tắt

MindSprintAI là ứng dụng web hỗ trợ người học tổ chức tài liệu, tạo và ôn flashcard, hỏi đáp với AI, quản lý công việc và theo dõi hoạt động học. Bản web chính dùng giao diện HTML/CSS/JavaScript, API ASP.NET Core 8, PostgreSQL, EF Core và Google Gemini.

Mục tiêu của MVP là gom các hoạt động học thường ngày vào một nơi, hỗ trợ ôn tập theo lịch và giảm thao tác tổng hợp tài liệu. Sản phẩm đã có các luồng chính cho flashcard/SRS, sổ tay AI, gia sư AI, Kanban, lịch học/thống kê và tài khoản. Chế độ offline hiện chỉ hỗ trợ một phần trải nghiệm phía trình duyệt; không nên hiểu là mọi dữ liệu và chức năng đều đồng bộ offline đa thiết bị.

Tài liệu thiết kế liên quan gồm ERD, kiến trúc phần mềm, Use Case, Activity và Sequence. Hai sơ đồ hoạt động và hai sơ đồ tuần tự hiện có thể được mở từ thư mục docs/architecture.

# 2. Vấn đề, người dùng và tầm nhìn MVP

## 2.1 Vấn đề cần giải quyết

- Tài liệu, ghi chú, câu hỏi ôn tập và lịch học thường nằm ở nhiều nơi.
- Người học phải tự chuyển tài liệu thành nội dung ôn tập và tự nhớ lịch ôn.
- Khi học bằng AI, việc gửi toàn bộ tài liệu lặp lại có thể làm tăng thời gian chờ, lượng token và chi phí.
- Người học cần nhìn thấy tiến độ và việc cần làm tiếp theo thay vì chỉ lưu nội dung.

## 2.2 Người dùng mục tiêu

Học sinh, sinh viên và người tự học cần một công cụ học cá nhân trên trình duyệt. MVP ưu tiên sử dụng cá nhân; không giả định có lớp học, nhóm chia sẻ hay quản trị viên trường học.

## 2.3 Mục tiêu MVP

1. Tạo và ôn flashcard theo lịch lặp lại cách quãng.
2. Lưu nguồn học tập, hỏi đáp theo nguồn và tạo tài liệu ôn tập bằng AI.
3. Hỗ trợ quản lý việc học bằng Kanban và lịch học.
4. Lưu tài khoản và dữ liệu trên server để dùng lại khi đăng nhập.
5. Duy trì một số thao tác học cục bộ khi trình duyệt mất mạng.

Các mục tiêu trên mô tả định hướng sản phẩm, không phải cam kết về KPI. Repository chưa có kết quả khảo sát người dùng hoặc benchmark chứng minh mức tăng hiệu quả học tập.

# 3. Phạm vi chức năng hiện có

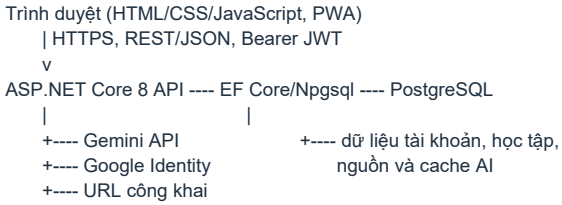
| Khu vực | Có trong mã nguồn | Giới hạn cần hiểu đúng |
|---|---|---|
| Tài khoản | Email/mật khẩu, Google Sign-In, access JWT và refresh token | Token phía trình duyệt được lưu bằng **localStorage**; xem mục bảo mật |
| Flashcard và SRS | Thẻ hệ thống và thẻ cá nhân, tiến độ ôn theo người dùng | Học cục bộ không đồng nghĩa đồng bộ ngoại tuyến cho mọi thao tác |
| Sổ tay AI | Notebook, nguồn văn bản/URL/tệp, hỏi đáp có trích dẫn và tài liệu ôn tập | Nội dung gửi cho Gemini; nguồn dài có thể bị giới hạn ngữ cảnh |
| Gia sư AI | Hỗ trợ giải thích, gợi ý và kiểm tra nội dung học | Kết quả do mô hình sinh cần được người học kiểm tra |
| Kanban | Tạo và di chuyển công việc giữa các trạng thái | Cần mạng để dùng API và đồng bộ dữ liệu server |
| Lịch và thống kê | Lịch học định kỳ, ngày học và streak | Báo cáo không đưa ra số liệu người dùng vì chưa có dữ liệu đo được |
| Ôn tập điểm yếu | Phân tích lịch sử ôn tập và gợi ý nội dung cần củng cố | Chất lượng phụ thuộc dữ liệu ôn tập đã ghi nhận |

### 3.1 Ngoài phạm vi MVP

Các nội dung sau chưa được coi là năng lực đã hoàn thành trong báo cáo này:

- Ứng dụng native cho iOS/Android.
- Chia sẻ notebook, học nhóm và cộng tác nhiều người.
- Đồng bộ ngoại tuyến có xử lý xung đột đầy đủ cho mọi loại dữ liệu.
- Bảng phân tích học tập nâng cao, báo cáo cho giáo viên và dự báo tiến độ.
- Định mức ngân sách AI theo người dùng hoặc dashboard chi phí theo thời gian thực.
- Chứng nhận hiệu quả học tập, hiệu năng hoặc an toàn dựa trên benchmark độc lập.

## 4. Kiến trúc và luồng dữ liệu




API gom các chức năng trong một ứng dụng backend theo tầng; các controller xử lý HTTP và quyền truy cập, services xử lý nghiệp vụ/AI, EF Core thao tác với PostgreSQL. Gemini API key chỉ được dùng phía server. Google Identity xác minh thông tin đăng nhập Google; nó không thay thế việc API kiểm tra quyền sở hữu dữ liệu.

Mã nguồn có các sơ đồ ERD, Use Case, Activity và Sequence trong thư mục kiến trúc. Sơ đồ ERD hiện là tài liệu thiết kế riêng; khi schema thay đổi cần đối chiếu lại với EF Core migrations trước khi phát hành bản báo cáo mới.

### 4.1 Triển khai và CI

Repository cấu hình API chạy bằng Docker trên Render cùng PostgreSQL; frontend được cấu hình để build/triển khai riêng. Workflow GitHub Actions chạy restore/build backend và build frontend. Job deploy backend chỉ chạy khi có push lên **main** và đủ secrets của Render; vì vậy job deploy bị bỏ qua trên pull request là hành vi theo cấu hình.

Tài liệu này không xác minh trạng thái dịch vụ Render/Vercel, secrets, database backup hay URL production đang hoạt động. Xem render.yaml, workflow CI/CD và CI-CD-SETUP.md.

## 5. Rủi ro chi phí AI và biện pháp hiện có

### 5.1 Nguồn phát sinh chi phí

- Tổng lượng văn bản và tệp đính kèm được gửi tới Gemini.
- Số lần gọi, số lượt chat và lượng nội dung đầu ra.
- Gọi lại do timeout, lỗi tạm thời hoặc fallback sang model khác.
- Nội dung nguồn thay đổi làm cache cũ không còn phù hợp.

Chi phí thực tế phụ thuộc model, bảng giá và quota đang áp dụng cho API key; báo cáo này không ước lượng tiền khi chưa có dữ liệu usage và mức giá tương ứng.

### 5.2 Cơ chế trong mã nguồn liên quan issue #12

- **Chọn đoạn cho chat:** nguồn văn bản được chia thành các đoạn xấp xỉ 1.800 ký tự, có phần chồng lấn 240 ký tự. Hệ thống xếp hạng đoạn theo từ khóa câu hỏi, chọn tối đa 12 đoạn và giới hạn context chat ở khoảng 26.000 ký tự.
- **Giới hạn đầu vào:** luồng Notebook xây dựng context có giới hạn theo tổng ký tự; tệp ảnh/PDF gửi trong một yêu cầu Gemini bị giới hạn tổng cộng 10 MiB.
- **Cache bền vững:** kết quả chat, summary, study guide và mind map được lưu theo notebook, loại yêu cầu, hash câu hỏi/yêu cầu và hash nguồn. Nguồn thay đổi sẽ tạo hash khác, tránh dùng lại kết quả của nguồn cũ.
- **Xử lý tải/lỗi:** GeminiService giới hạn số yêu cầu đồng thời, đặt timeout, retry lỗi tạm thời và thử các model fallback được cấu hình.

Cache hiện không áp dụng cho mọi thao tác sinh nội dung: FAQ, timeline, flashcards, quiz, audio và một số luồng tutor vẫn có thể gọi Gemini lại. Việc hỏi lại chỉ tiết kiệm lượt gọi khi nội dung notebook và yêu cầu khớp với khóa cache.

### 5.3 Mức hiệu quả đã biết và việc cần đo

Mã nguồn ghi log ước tính token từ số ký tự chia cho bốn. Đây chỉ là chỉ báo tương đối, không phải bộ đếm tokenizer của Gemini hay hóa đơn chi phí. Repository chưa chứng minh các tỷ lệ tiết kiệm 60%, 70% hoặc 80-95%; các con số như vậy không được dùng làm kết quả báo cáo.

Để đánh giá hiệu quả, cần thu thập usage thực theo model (input/output tokens, số lần gọi, retry, cache hit/miss, thời gian, lỗi), so sánh cùng một tập câu hỏi/tài liệu trước và sau tối ưu, đồng thời loại trừ dữ liệu nhạy cảm khỏi log. Nên bổ sung quota hoặc ngân sách theo người dùng trước khi mở rộng lượng người dùng.

## 6. Bảo mật và quyền riêng tư

### 6.1 Kiểm soát đang có

- Mật khẩu được băm bằng **PasswordHasher<User>** của ASP.NET Identity.
- Access JWT có thời hạn mặc định 15 phút; refresh token có thời hạn 7 ngày.
- Refresh token được sinh bằng bộ tạo số ngẫu nhiên mật mã, xoay vòng khi refresh và có thể thu hồi một phiên hoặc tất cả phiên.
- API kiểm tra người dùng đăng nhập và lọc các tài nguyên cá nhân theo UserId ở các luồng liên quan.
- Production yêu cầu cấu hình khóa JWT đủ độ dài và danh sách origin CORS; khóa Gemini được đọc từ cấu hình phía server.
- Các endpoint Google challenge/sign-in được áp dụng rate limit 20 yêu cầu/phút/IP.

### 6.2 Rủi ro còn lại

| Rủi ro | Ảnh hưởng | Trạng thái và hướng xử lý |
|---|---|---|
| Token ở **localStorage** | XSS có thể đọc access/refresh token | Cân nhắc chuyển refresh token sang cookie **HttpOnly**, **Secure**, **SameSite** và thiết kế chống CSRF; giảm bề mặt XSS |
| Refresh token lưu nguyên giá trị trong DB | Lộ DB có thể làm lộ token còn hiệu lực | Lưu hash token thay vì token gốc; giới hạn truy cập DB và chuẩn bị quy trình xoay/revoke |
| Thu hồi phiên | Access JWT đã phát hành không bị thu hồi tức thời | Token vẫn dùng được tới khi hết hạn; cân nhắc denylist/phiên bản tài khoản nếu cần thu hồi ngay |
| Đăng nhập email/mật khẩu | Policy **google-auth** không áp dụng cho endpoint login thông thường | Bổ sung rate limit và theo dõi thử sai cho register/login |
| Endpoint demo | API còn route demo với thông tin đăng nhập cố định trong mã | Tắt hoặc bảo vệ route demo ở production; seeder không tạo demo user không tự vô hiệu hóa endpoint |
| Dữ liệu gửi tới AI | Nội dung tài liệu/câu hỏi được gửi tới Gemini để xử lý | Thông báo rõ cho người dùng, không gửi token/secret, xem xét thời hạn lưu và điều khoản nhà cung cấp |
| Sai lệch nội dung AI | Có thể tạo câu trả lời sai hoặc dẫn nguồn không đủ | Giữ trích dẫn, báo rõ nguồn thiếu và yêu cầu người học kiểm chứng; cần bộ đánh giá chất lượng |
| URL bên ngoài | Có thể dẫn tới nội dung độc hại hoặc tài nguyên nội bộ nếu kiểm tra sai | Tiếp tục kiểm thử redirect/DNS/IP/giới hạn dung lượng; không tin nội dung nguồn như chỉ thị |
| Khôi phục dữ liệu | Mất dữ liệu nếu chưa có backup/restore được kiểm chứng | Xác lập lịch backup, retention và diễn tập khôi phục PostgreSQL |

Các biện pháp trên mô tả mã nguồn/configuration đã rà soát; chúng không phải chứng nhận bảo mật hay xác nhận production đã cấu hình đầy đủ.

# 7. Rủi ro sản phẩm và vận hành

| Rủi ro | Tác động | Giảm thiểu tiếp theo |
|---|---|---|
| Quota hoặc gián đoạn Gemini | Chat/tạo tài liệu bị chậm hoặc không dùng được | Theo dõi lỗi, cache có phạm vi rõ ràng, quota và thông báo retry phù hợp |
| Cold start hoặc giới hạn gói hosting | API phản hồi chậm hoặc dịch vụ bị giới hạn | Đo thời gian thực tế, đặt health/uptime monitor và rà soát gói theo nhu cầu |
| Migration lỗi khi khởi động | API có thể không sẵn sàng nếu schema không cập nhật được | Chạy migration trên môi trường staging và có kế hoạch backup/rollback |
| Offline không đầy đủ | Dữ liệu cục bộ và server có thể khác nhau | Nêu rõ tính năng nào offline; thiết kế đồng bộ/xung đột theo từng loại dữ liệu |
| Thiếu đo kiểm định lượng | Không biết rõ hiệu năng, chi phí hay chất lượng học | Thực hiện test plan, lưu số liệu và liên kết kết quả với phiên bản phát hành |

# 8. Kiểm thử và bằng chứng

Workflow hiện cấu hình build backend và frontend; workflow không có bước **dotnet test**. Repository có kế hoạch kiểm thử Sprint 4 và yêu cầu phi chức năng, nhưng tài liệu kế hoạch không đồng nghĩa các phép đo đã chạy hoặc đạt.

Trước khi phát hành cần lưu bằng chứng có commit, môi trường, cấu hình, dữ liệu thử, kết quả và giới hạn của mỗi phép đo. Báo cáo này không công bố số người dùng, điểm hài lòng, thời gian phản hồi, mức tiết kiệm tiền hoặc kết quả kiểm thử xâm nhập khi chưa có hồ sơ tương ứng.

# 9. Hướng phát triển

## Ưu tiên trước khi phát hành rộng

1. Khóa route demo và bổ sung bảo vệ brute-force cho đăng nhập email/mật khẩu.
2. Băm refresh token khi lưu, đánh giá chuyển token dài hạn khỏi **localStorage**, ghi rõ vòng đời phiên.
3. Bổ sung đo usage Gemini và quota để biết chi phí theo tính năng/người dùng.
4. Hoàn tất test bảo mật, backup/restore, migration và smoke test trên staging.
5. Đồng bộ lại ERD với migrations hiện hành và đưa các sơ đồ phụ thuộc vào gói báo cáo phát hành.

## Ngoài MVP

- Đồng bộ offline đa thiết bị có xử lý xung đột.
- Học nhóm, chia sẻ notebook và cộng tác.
- Ứng dụng mobile native và mở rộng đa ngôn ngữ.
- Phân tích tiến độ sâu hơn, dashboard/nhắc học cá nhân hóa.
- Mở rộng cache theo loại tác vụ sau khi đánh giá tính đúng đắn và chính sách dữ liệu.

Các mục này là đề xuất lộ trình, không phải tính năng đã cam kết hoặc đã triển khai.

# 10. Kết luận

MindSprintAI đã có nền tảng web cho các luồng học tập chính và tích hợp Gemini ở phía server. Issue #12 bổ sung chọn ngữ cảnh theo câu hỏi và cache cho một số kết quả Notebook, giúp hạn chế gửi lại dữ liệu trong các trường hợp khớp cache; repository hiện chưa có số đo hóa đơn để kết luận mức giảm chi phí. Issue #5 bổ sung JWT access ngắn hạn, refresh rotation và thu hồi refresh session, nhưng còn các điểm cần xử lý trước khi khẳng định an toàn production, đặc biệt là token trong **localStorage**, refresh token lưu gốc trong DB và route demo.

Vì vậy, phạm vi MVP phù hợp để tiếp tục nghiệm thu nội bộ. Việc phát hành rộng nên đi cùng các bước hardening bảo mật, kiểm thử có bằng chứng, theo dõi chi phí AI và quy trình khôi phục dữ liệu.

# Tài liệu tham chiếu

- README dự án
- Issue #5 - JWT, refresh token và thu hồi phiên
- Issue #12 - Tối ưu chi phí AI
- Issue #20 - ERD và sơ đồ UML
- Issue #21 - Báo cáo, tầm nhìn MVP, phân tích rủi ro
- NotebookAi.cs, GeminiService.cs
- TokenService.cs, AuthController.cs
- Program.cs, CI/CD workflow
- ERD, kiến trúc phần mềm, Use Case
- Activity Notebook, Activity Kanban
- Sequence xác thực/flashcard, Sequence Notebook